

# AlphaInsure Data Classification & Handling Standard

Reference: DCH · Version 3.0 · Effective 1 January 2026

|                   |                                              |
|-------------------|----------------------------------------------|
| Document owner    | AlphaInsure Data Protection Office           |
| Approved by       | AlphaInsure Chief Data Officer and DPO       |
| Review cycle      | Annual                                       |
| Previous version  | 2.8 (April 2025)                             |
| Classification    | Internal                                     |
| Regulatory basis  | GDPR; local insurance regulator requirements |
| Related standards | AHS, CKS, ASC, FIN                           |

## 1. Purpose and scope

This standard establishes how AlphaInsure data is classified and how data in each class must be handled across its lifecycle: creation, storage, transmission, processing, access, and deletion. It is the authoritative reference for architecture reviews, data protection impact assessments, and incident response.

## 2. Classification levels

AlphaInsure data is classified into four levels, in order of increasing sensitivity:

| Level        | Examples                                                                          | Disclosure impact                                         |
|--------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------|
| Public       | Published marketing materials, product brochures, press releases                  | No impact; disclosure is intentional                      |
| Internal     | Internal communications, process documentation, non-sensitive business data       | Minor reputational risk                                   |
| Confidential | Aggregated customer data, commercial terms, pricing models, third-party contracts | Commercial damage, competitive disadvantage               |
| Restricted   | Personal data, financial data, health data, credentials, cryptographic keys       | Regulatory breach, customer harm, material financial loss |

**DCH-01** Every application **MUST** declare its highest data classification level in the intake form. The classification reflects the most sensitive data element the application processes, stores, or transmits, even transiently.

**DCH-02** Personal data, financial data, health data, and credentials are always **Restricted**. This classification is non-negotiable and cannot be reduced by anonymisation or aggregation claims without formal review by the Data Protection Office.

## 3. Handling requirements by class

| Control            | Public       | Internal     | Confidential | Restricted                 |
|--------------------|--------------|--------------|--------------|----------------------------|
| Encryption at rest | Not required | Platform key | Platform key | Customer-managed key (CMK) |

| Control               | Public       | Internal      | Confidential     | Restricted                                  |
|-----------------------|--------------|---------------|------------------|---------------------------------------------|
| Encryption in transit | Not required | TLS 1.2+      | TLS 1.2+         | TLS 1.2+ with cert verification             |
| Intra-cluster TLS     | Not required | Recommended   | Required         | Required (all hops)                         |
| Access control        | None         | Authenticated | RBAC + audit log | RBAC + audit log + dual control for admin   |
| Data residency        | Any region   | EU preferred  | EU required      | EU required; transfers require DPO approval |
| Log visibility        | OK           | OK            | Redact secrets   | No PII in logs; secrets never logged        |
| Non-prod handling     | As-is        | As-is         | Subsetted        | Anonymised or synthetic only                |

**DCH-03** Restricted data MUST be encrypted at rest using a customer-managed key (CMK) held in AWS KMS or Azure Key Vault. Platform-managed keys are not sufficient for Restricted data.

**DCH-04** Restricted data MUST be encrypted in transit using TLS 1.2 or higher, on every network segment it traverses. This includes connections between pods within the same cluster, connections to managed services, and connections to external parties. Unencrypted internal hops are a breach of this clause.

**DCH-05** TLS connections handling Restricted data MUST verify the server certificate. Disabling certificate verification (for example, via `sslmode=require` without `verify=full`, or `verify=False` in an HTTP client) is prohibited.

## 4. Credentials and secrets handling

Credentials (passwords, API keys, OAuth client secrets, database credentials, cryptographic private keys, signing keys) are always Restricted regardless of the data they unlock.

**DCH-06** Credentials MUST NOT appear in application logs, metrics, exception traces, crash dumps, telemetry, or error responses. Workloads that log request bodies MUST scrub or mask fields recognised as credentials.

**DCH-07** Credentials MUST NOT be stored in environment variables when a file-mount option is available. See CKS-11 for the pod-level requirement.

**DCH-08** Credentials MUST be rotated on the following triggers: (a) suspected compromise; (b) departure of a person with access; (c) scheduled rotation per the secret manager's rotation policy.

### **IMPORTANT** — Credential incidents

A credential disclosed in logs, source control, or a public repository — even briefly — MUST be treated as compromised and rotated immediately. Rotation without reporting is not an acceptable response; the disclosure MUST be reported to Group Security within 24 hours.

## 5. Personally identifiable information (PII)

**DCH-09** PII is Restricted and subject to GDPR. Processing of PII MUST have a lawful basis recorded in the application's data processing register.

- DCH-10** PII MUST remain within EU regions. Replication of PII across regions (including within the EU) requires documentation of the purpose. Replication outside the EU requires approval from the Data Protection Office and a documented transfer mechanism (Standard Contractual Clauses or adequacy decision).
- DCH-11** Logs containing PII are prohibited. Where the need to log PII is asserted (e.g. for fraud investigation), the logging pipeline MUST apply tokenisation or masking before persistence, and access to the raw data MUST be restricted to a named group.
- DCH-12** Non-production environments MUST NOT contain real PII. Teams MUST use synthetically generated data or properly anonymised data. Copying a snapshot of production into a non-production environment is prohibited.
- DCH-13** Applications processing PII MUST implement right-to-be-forgotten handling within GDPR deadlines. The deletion procedure MUST be documented in the application's runbook and verified during annual reviews.

## 6. Financial and regulated data

- DCH-14** Financial data (premiums, claim amounts, account numbers, payment card data) is Restricted. Payment card data is additionally subject to PCI-DSS, which imposes controls beyond this standard.
- DCH-15** Financial data records MUST be retained for 7 years from the end of the business relationship, in line with local insurance regulatory requirements. Retention shorter than 7 years is a breach unless a regulatory exemption is documented.

## 7. Data protection controls

- DCH-16** Applications processing Restricted data MUST implement data loss prevention (DLP) controls for outbound traffic. The AlphaInsure DLP solution MUST be enabled on any egress path where Restricted data may flow.
- DCH-17** Data stores containing Restricted data MUST have audit logging enabled. Audit logs MUST be shipped to the central SIEM and retained per the FinOps standard (see FIN-17).
- DCH-18** Administrative access to data stores containing Restricted data MUST be protected by just-in-time access workflows. Standing admin access is prohibited.

## 8. Incident response

- DCH-19** Security incidents involving Restricted data MUST be reported to Group Security within 4 hours of detection. Incidents involving PII MUST additionally be reported to the Data Protection Office within the same window.
- DCH-20** Application teams MUST maintain an incident response runbook covering: detection of unauthorised data access, containment procedures, communication templates, and escalation contacts.

## 9. Third-party processors

- |               |                                                                                                                                                           |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>DCH-21</b> | Third parties processing AlphaInsure data MUST be covered by a Data Processing Agreement (DPA). The DPA list is maintained by the Data Protection Office. |
| <b>DCH-22</b> | Onboarding a new third-party processor for Restricted data requires approval from the Data Protection Office before any data is transferred.              |

## 10. Related standards

- **AHS** — AlphaPaaS Application Hosting Standard
- **CKS** — AlphaPaaS Container & Kubernetes Security Standard
- **ASC** — AlphaPaaS Approved Services Catalog
- **FIN** — AlphaPaaS FinOps & Cloud Cost Standard